



Nationaal Cyber Security Centrum
Ministerie van Justitie en Veiligheid

Five Basic Principles of Digital Resilience

Introduction

Digital resilience is vital if your organisation wants to benefit optimally from the opportunities and possibilities of digitisation. The reality is that organisations have to deal with digital threats on a daily basis, regardless of their size. Such threats may lead to a data leak or downtime of the production environment, for instance, which may have a high impact that includes reputational damage or even puts the organisation's business continuity at risk. This means that organisations must defend themselves against these threats by improving their digital resilience.

Intended audience

The 5 basic principles have been established in such a way that they can be used and implemented by any organisation. Whether you have already made strides in improving your organisation's digital resilience or still have a long way to go, the 5 basic principles will help you move forward. If you are self-employed or an SME, [please go to the Digital Trust Center page for more information](#). Bigger companies and NIS2 organisations can turn to the NCSC.

Table of content

Why did we define 5 basic principles of digital resilience?	3
Basic principle 1: Map your risks	3
Basic principle 2: Stimulate safe behaviour	5
Basic principle 3: Protect systems, applications and devices	6
Basic principle 4: Manage access to data and services	8
Basic principle 5: Prepare for incidents	10

Why did we define 5 basic principles of digital resilience?

Many digital incidents are caused by not having effective basic security measures in place, which is unfortunate because an organisation's digital resilience can usually be improved significantly simply by taking some relatively easy steps. Even so, all organisations are different so it is impossible to present a one-size-fits-all set of measures. With the 5 basic principles of digital resilience, we provide a number of starting points to develop a healthy and sound cyber-security strategy.

Basic principle 1: Map your risks

Many cyber attacks are successful because organisations are not aware of the risks to which they may be exposed. Whether it is an old server that offers unpatched access via the internet or a forgotten unsecured network port, such risks may lead to incidents with far-reaching consequences.

Incidents can have a major impact on your organisation. You need a suitable digital resilience level to ensure smoothly running business operations. A suitable level means that you achieve a protection level for information and information systems that matches your business objectives. You can gain insight into this by mapping your risks and implementing suitable measures. We call this risk management.

Risk management means that you know what systems, information and environment you have, what threats you might encounter, and what risks you are willing to take. It provides insight into your protectable interests and what opportunities you have to grow your resilience. You can also map (technical) dependencies on vendors and suppliers and the risks they represent.

Why does this basic principle matter?

It is impossible to achieve 100% digital resilience. Being fully aware of your risks means that you can

make well-considered choices in the measures required for risk mitigation. So mapping your risks means knowing what interests you need to protect and what suitable measures are available. Risk management ensures that you can work continuously on improving your digital resilience. What can you do?

Perform a risk assessment

You can perform a risk assessment to find out what measures will be suitable for your organisation. A risk assessment helps your organisation to map relevant threats, your organisation's crown jewels or protectable interests, and what is required to be resilient if these risks occur. This helps you to protect the right things in the right way: not so much that it becomes too costly or unworkable but in such a way that it reduces any potential risk to your business continuity. This provides a deeper understanding into which measures, besides the basic ones, add value to your organisation.

Organise risk management

To ensure that risk assessment is not performed in isolation, it is a good idea to set up a risk management process. This guarantees that risk assessments are carried out at regular intervals, that it is clear what measures are implemented, in what timeframe and by whom, as well as where ownership of the risk lies.

In addition to providing a framework for identifying and responding to risks, the risk management process also makes transparent how the organisation handles risks and how these are tackled and mitigated.

Don't forget your supply chain

Conducting a risk assessment and setting up risk management requires constant attention. Would you like to discover how to organise this properly within your organisation? The risk management roadmap provides more information on risk management. It was created to offer insights into and a clear overview of risk management in the digital domain. It is used as a reference and provides a comprehensive roadmap to organisations that want to level up their digital resilience.

Guidelines and articles for basic principle 1

NIS2:

Requires entities to implement suitable and proportionate technical, operational and organisational measures in line with the risks that occur. The basic principles help you take the first steps in mapping these risks.

Articles 20.2, 21.2a and 21.2d of the NIS2 Directive also cover this basic principle.

If you are looking for an overview of NIS2-related publications, [check out the list here](#).

Link to NIS2 Directive (EN): [L_2022333NL.01008001.xml \(europa.eu\)](#)

ISO/IEC 27001: Provides starting points for setting up an ISMS.

BIO: Chapter 1: Information security in government organisations

Basic principle 2: Stimulate safe behaviour

Most cyber incidents involve human beings. There is a lot of interaction between humans and systems on a daily basis, and unfortunately that is where it often goes wrong. Moreover, attackers use clever influencing tactics to elicit unsafe behaviour. Infamous examples are phishing mails or leaving an infected flash drive. Sometimes people unwittingly cause a data leak without any intervention from an attacker,

so stimulating safe behaviour is vital to improve digital resilience. You can achieve this by heightening your employees' awareness of risks, offering training on how to handle incidents, but also by fostering a culture that encourages employees to feel safe and report incidents when they occur. Technical solutions can support this, for instance spam filters to recognise phishing or tools to create and store passwords in a secure manner. Investing in your employees means turning them into a strong link in the cybersecurity chain.

Why does this basic principle matter?

Accidents happen. People are susceptible to manipulation and deception and sometimes high pressure or distraction at work lead to mistakes, so it is important to educate your employees and provide training, so they know how to use the information and systems made available to them safely and responsibly. A safe culture that encourages reporting incidents is vital here. Train your employees by familiarising them with scenarios in which things go wrong so they know what to do when things go awry. What can you do?

Help employees through awareness and training

You need knowledge and expertise to handle information and systems safely. Help your employees as well as management by making them aware of the risks they run, for instance due to phishing or downloading malware. Also teach them how to deal with such things in a safe manner and what to do when things go wrong. Moreover, think about insider risks and tackle these at regular

intervals by means of an awareness programme or training.

Make sure to devote attention to fostering a safe reporting culture

It is never fun to admit that you made a mistake, especially if there is a lot at stake and you blame yourself. This may make it really difficult to report an incident but timely detection of an incident is vital if you want to limit the consequences as an organisation. You can lower the threshold and create a safe reporting culture by facilitating incident reporting, actively encouraging your employees to report issues and reward people who actually report incidents.

Support people with technology

Security measures can also throw up obstacles, for instance by requiring complex passwords. If a person must come up with complicated passwords and remember them for a number of different accounts, it makes sense to expect that they will use (and reuse) passwords that they can easily remember. In this case, the technology does not take account of the human aspect and this leads to unsafe behaviour. You can make it easier, for instance by implementing user-friendly password managers or generating alerts when receiving potential phishing mails. Leverage technology to help people make safer choices.

Guidelines and articles for basic principle 2

- NIS2:

Requires entities to implement suitable and proportionate technical, operational and organisational measures in line with the risks that occur. The basic principles help you take the first steps in mapping these risks.

Article 20.2 of the NIS2 Directive also covers this basic principle.

If you are looking for an overview of NIS2-related publications, [check out the list here](#).

Link to NIS2 Directive (EN): [L_2022333NL.01008001.xml \(europa.eu\)](https://eur-lex.europa.eu/eli/dir/2022/2555/oj)

- **ISO/IEC 27002**: Chapter 6: People Controls

- **BIO**: Chapter 7: Secure Personnel

Basic principle 3: Protect systems, applications and devices

Vendors often deliver software, computer and networking devices with default settings, which generally cover more features than the organisation needs and offer attackers with an unnecessary additional surface to attack. Once having gained access, they will try to move through the network searching for valuable information.

As an organisation, you naturally want to prevent things like this from happening. You can do this by ensuring that your systems, applications and devices are well protected ('hardened'). Implementing updates and patches in a timely manner is vital because it helps eliminate vulnerabilities quickly. You also want to be able to respond to an attack as quickly as possible. Monitoring and detection solutions help you keep on top of what is happening and limit damage.

Why does this basic principle matter?

Using default settings means running the risk that systems, applications and devices are more accessible than you want them to be. Unnecessary features also expand your attack surface so you will have to plug more leaks to achieve digital resilience. To improve your protection level, you need to reduce the attack surface and use monitoring and

detection to respond to potential attacks in a timely manner. What can you do?

Limit your attack surface

Reducing your attack surface means deactivating, closing down or deleting everything that is not necessary to realising your business objectives. You can do this by deleting, disabling, making inaccessible or restricting features and communication openings (system hardening). Examples include technical services, communication protocols, software, user accounts and system services.

Use your risk assessment to determine what elements you need and which ones are unnecessary. Also consider mobile devices, such as smartphones and tablets, which must be configured in a secure manner to ensure that confidential data remains inaccessible even in case of theft, loss or incursion.

Implement network segmentation

If an attacker does gain access, network segmentation can limit the impact of an attack significantly. Segmentation means dividing a network into smaller sections and prevents viruses or attackers from spreading throughout the network.

Network segmentation is a measure that can limit the impact of various types of cyber attacks. Apply the principle that network traffic is not allowed overall and then add specific firewall rules for traffic that is necessary.

Ensure timely incident detection

Every organisation may have to deal with malicious activities on their network or digital attacks. Detection is an approach that deploys technological methods to gain insight into the threats resulting from these activities. Detection provides clear insight into an incident and allows you to refine your security measures. You will need log files to set up detection correctly, and you must be able to read and monitor these files. Determine what log files you need. Ensure that they are forwarded to a centralised logging server so your monitoring system can be configured the right way. Use automated log analysis where possible and think about retention periods for your log files.

Set up patch management

By setting up a patch management process, you create a process to identify, test and install software updates. Map all of the software and systems used within your organisation, including web browsers and plug-ins.

Implement data encryption

Encrypting your business information ensures that data are unusable if they ever fall into the hands of attackers. Encryption prevents the data from being read unless you have the key, which may be a separate password supported by cryptography, but it can also be managed by your workstation or telephone, for example. This means that the encryption system is user-friendly and can be applied to all data.

Data encryption can be implemented whilst data are in transit and/or once they are stored, i.e. at rest. Encrypt hard drives, laptops, mobile devices and flash drives that contain business information. You must also consider how your data are stored in cloud solutions or on servers.

Ensure that such data also are encrypted so you are not dependent on the reliability of specific vendors or suppliers and take full responsibility as a data owner.

Guidelines and articles for basic principle 3

- NIS2:

Requires entities to implement suitable and proportionate technical, operational and organisational measures in line with the risks that occur. The basic principles help you take the first steps in mapping these risks.

Articles 21e, 21g, 21h and 21j of the NIS2 Directive also cover this basic principle.

If you are looking for an overview of NIS2-related publications, check out the list here. [Bekijk hier het overzicht.](#)

Link to NIS2 Directive (EN): [L_2022333NL.01008001.xml \(europa.eu\)](#)

- **ISO/IEC 27002**: Chapter 8: Technological Controls

- **BIO**: Chapter 10: Cryptography. Chapter 12: Operations Security. Chapter 13: Communications Security. Chapter 14: Information System Acquisition, Development and Maintenance

Basic principle 4: Manage access to data and services

Organisations need to provide people access to information, systems and locations so they can do their job. It is important that employees in and partners outside your organisation only have access matching their activities for the duration of those activities (least privilege). This will reduce the risk of accidents and exploitation to the minimum. Only grant your people access to the information, systems and locations they need to perform their tasks.

Moreover, access must be managed deliberately through identity and access management for both logical and physical access. This will limit the impact of user errors as well as reduce the attack surface for malicious parties should they manage to gain access, since it limits their access to the role for which they were granted access. Access to service accounts, machine accounts and functional accounts should also be limited to what is strictly necessary.

Why does this basic principle matter?

By limiting and controlling access rights for each person, you prevent people within and outside of your business from gaining access to systems and data they do not need to do their job. Moreover, it protects against attackers once they gain access since they can only see what is accessible with the rights they were assigned. What measures can you take?

Implement access management and access policies

Role-based access control can make rights management easier. Allocate minimal rights according to the principle of least privilege, which means that users are granted minimal rights unless they need more access to do their job.

- Assign ownership for all data, generally a line manager.
- Always adhere to the principle that the business is responsible for determining what data is stored and how the respective rights are determined. An ICT organisation can implement this on behalf of the

data owner at best, but it cannot decide or determine this for the data owner.

- Make sure you have processes in place for employee entry, exit and internal movement.
- Give new employees access only to the resources they need, including physical spaces such as server rooms or spaces where sensitive information is stored.
- Block access to data and systems immediately for accounts of exiting employees.
- Delete unused accounts.
- Deactivate service accounts and activate them only when maintenance is performed..

Configuring and implementing access control is also called Identity and Access Management (IAM).

Use personal accounts

Make sure that access to data and services is personal, with each employee having their own user account. Avoid generic accounts that are shared between multiple employees, for example, or multiple employees of a supplier. This also applies to service accounts, which are accounts used by systems for interfacing purposes. Avoid such accounts wherever possible. Instead, use a modern API and at the very least implement a password policy if your systems require a service account. Change default passwords of devices and systems upon installation or commissioning.

Implement strong authentication

Authentication is the technology a system uses to verify user identity and grant users access to data or systems. It is important to implement strong authentication so you can be sure users gain access with their real identity.

Use multi-factor authentication

A factor is a method by which users log on. There are three categories:

something you know (e.g. a password), something you have (such as a token), or something you are (a fingerprint, for instance). Multi-factor authentication means logging in using factors from at least two of these categories. Using two factors is also referred to as 'two-factor authentication'.

Examples of multi-factor authentication are a password combined with a token or a fingerprint combined with a one-time code.

Implement multi-factor authentication for accounts that are accessible from the internet, accounts that have administrative rights, and accounts on critical systems. Using multi-factor authentication prevents attackers from gaining access to an account by guessing or obtaining the password, for instance through a phishing attack.

Avoid passwords or use strong passwords

Whenever possible, opt for password-free solutions. Passwords are vulnerable and outdated as a security mechanism.

If this is not feasible, use strong passwords (or passphrases) and provide support to your users with password managers. A strong password is not easily guessed and difficult for a computer to crack. An important condition is that its actual uniqueness is part of a password's strength.

Secure log on

In addition to determining a secure logon method for users, it is also important to consider what devices should be permitted to log onto your systems and from what locations. You can configure a specific area or set to limit or block access to systems from unknown locations and by unknown devices. If your organisation operates mainly in the Netherlands, with employees who live in the Netherlands and only use specific devices, consider whether this can also be mandated as a system-level standard.

Finally, if limiting or blocking access proves unfeasible, it is also possible to detect logon attempts from unknown sources and alert users to this, by email for example, so they can take action to address the issue..

Guidelines and articles for basic principle 4

- NIS2:

Requires entities to implement suitable and proportionate technical, operational and organisational measures in line with the risks that occur. The basic principles help you take the first steps in mapping these risks.

Article 21g of the NIS2 Directive also covers this basic principle.

If you are looking for an overview of NIS2-related publications, [check out the list here](#).

Link to NIS2 Directive (EN): [L_2022333NL.01008001.xml \(europa.eu\)](https://eur-lex.europa.eu/eli/dir/2022/2554/oj)

- ISO/IEC 27002: Chapter 5 (5.15-18): Organisational Controls

- BIO: Chapter 9: Access Control

Basic principle 5: Prepare for incidents

You can't prevent each and every incident. And if it does happen, an organisation's digital resilience will determine how fast they can go back to business as usual. Preparing for incidents means that your organisation devotes attention to business continuity, fallback and recovery plans, incident response plans, and back-up strategies. Practicing plans and back-up testing at regular intervals are necessary to ensure the highest possible readiness for incidents that impact digital space.

Why does this basic principle matter?

The question is not whether but rather when you will be facing an insider threat. When you are under attack, every second counts. You do not want to lose time in determining your strategy – you must already have one. Thinking about how you will respond to incidents and how you can recover, and practicing digital attack scenarios on a regular basis means you will be well prepared if a digital incident occurs. What can you do?

Know how to respond to incidents

A timely and adequate incident response is vital in preventing or limiting damage. Your risk assessment will allow you to come to a reasonable estimate of the scenarios to which your organisation may be susceptible. You can cover these scenarios in (incident response) plans that will help you respond to the associated incident.

Recovery after an incident

Resilience is about developing and implementing suitable procedures and measures that will help you go back to business as usual in the event of a cyber incident. These may include a Disaster Recovery Plan or regular back-up testing. Such measures support timely recovery to limit the impact of an incident and safeguard continuity. The speed at which an organisation recovers depends on the gravity of the incident, but also on the measures that the organisation implemented beforehand.

Exercising, testing and training

In practice, response and recovery plans are not always easily implemented. One of the main reasons is that these plans have not been adequately practiced, tested and trained. Practicing your response and recovery capacities and the underlying scenarios will help you gain insight into your resilience should an incident occur.

In addition, you must devote attention to regular staff education and training. Employees must become familiar with their tasks in the response and recovery team, internalise processes, understand the procedures, and gain practical experience in doing what they have to do.

Develop a back-up policy

You should have a back-up policy in place to protect your organisation against data loss should any problems arise. Such a back-up policy contains your requirements for storing and protecting your data, which are defined in part on the basis of your risk assessment.

Create back-ups

Creating and testing back-ups on a regular basis is vital to ensure rapid recovery from an incident. Devise an approach for implementing the back-ups when it matters: as part of a recovery process to minimise interruptions of your business operations. It is therefore important not only to safeguard your data, but also to have a tried and tested way of quickly recovering your data if the situation warrants it. Your method should be tested to demonstrate its technological feasibility, but it should also be practised so that all stakeholders know exactly what to do if your business operations are interrupted due to ICT issues.

Test back-ups

Consider what data needs to be backed up and what the minimum retention period for back-up files should be. Test the back-up restoration process to minimise disruption of your business operations in the event of data loss. Practice the recovery process with employees who need to be able to do execute these tasks in a live situation.

The 3-2-1 rule can help you set up your back-up process: it means that you have 3 versions of your data (your production data and two back-ups) on 2 different media (e.g. physical hard drives, tape and in the cloud), with 1 copy in a different location for disaster recovery (e.g. a different data centre or a vault away from your office). Storing back-ups in a different location allows you to recover your systems, for instance if your company network is encrypted using ransomware.

Guidelines and articles for basic principle 5

- NIS2:

Requires entities to implement suitable and proportionate technical, operational and organisational measures in line with the risks that occur. The basic principles help you take the first steps in mapping these risks.

Articles 20, 21g and 23 of the NIS2 Directive also cover this basic principle.

If you are looking for an overview of NIS2-related publications, [check out the list here](#).

Link to NIS2 Directive (EN): [L_2022333NL.01008001.xml \(europa.eu\)](#)

- **ISO/IEC 27002**: Chapter 5.26: Response to Information Security Incidents

Chapter 5.27: Learning from Information Security Incidents Chapter 8.13: Information Back-up

- **BIO**: Chapter 6: Organising Information Security Chapter 12.3: Back-up

Chapter 16: Managing Information Security Incidents

Uitgave

Nationaal Cyber Security Centrum (NCSC)

Postbus 117, 2501 CC Den Haag

Turfmarkt 147, 2511 DP Den Haag

070 751 5555

Meer informatie

www.ncsc.nl

info@ncsc.nl

[@ncsc_nl](https://twitter.com/ncsc_nl)

May 2025